

Oversight of Randers Municipality

Date: 22-12-2023

Decision

Public Authorities

Criticism

Serious Criticism

Supervision / Self-Management Case

Processing Security

Fundamental Principles

Risk Assessment and Impact Analysis

The Data Protection Agency has made a decision in five oversight cases regarding the processing security in AULA.

The Data Protection Agency found reason to issue orders for the preparation of impact analyses in two of the cases.

Additionally, the oversight has expressed criticism and serious criticism in the cases.

Journal Number: 2023-423-0008.

### Summary

The Data Protection Agency initiated oversight in the autumn of 2021 concerning the processing of personal data in the IT system AULA by a total of six selected municipalities. The oversight focused on compliance with the data protection regulation's rules on processing security and impact analysis.

"When schools/childcare institutions and parents communicate via AULA, sensitive and confidential information about children is often included. It is therefore important that municipalities take good care of the information in AULA. According to the data protection regulation, children are entitled to special protection," says Signe Vestergård, special consultant at the Data Protection Agency.

The Data Protection Agency has now made decisions in all cases except one, as this case contains some additional elements.

The oversight is a continuation of the Data Protection Agency's previous oversight of Kombit A/S (hereinafter KOMBIT) in December 2019. During that oversight visit, the Data Protection Agency found that KOMBIT could not be considered the data controller for AULA under Article 4, No. 7 of the data protection regulation. At the oversight meeting, the Data Protection Agency informed KOMBIT that KOMBIT should ensure that all municipalities were informed of their data responsibilities and that KOMBIT should provide all necessary materials and information to the municipalities in this regard.

The Data Protection Agency finds that the oversight cases raise some general data protection legal issues across municipalities that can be better handled collectively rather than separately at the individual municipalities. Therefore, the Data Protection Agency has chosen to inform the Danish Municipalities' Association (KL), the Agency for IT and Learning, and Kombit A/S (hereinafter KOMBIT) about the oversight's decisions in these cases. At the same time, the Data Protection Agency has formulated some recommendations for further work on processing security in AULA.

Furthermore, the Data Protection Agency will provide the same recommendations in a letter to all municipalities in the country, where the oversight will also inform about the decisions. The purpose of the information to the municipalities is to encourage them to consider whether the material gives rise to (further) assessments, etc., or to ensure the implementation of additional security measures concerning their processing of personal data in AULA.

### Impact Analysis

Although the five municipalities use the same technical solution (AULA) for the same processing activities, they have had a markedly different approach to the issue of impact analyses.

All five municipalities have received criticism or serious criticism in the part of the cases concerning impact analysis. Two of the municipalities have received serious criticism for not having prepared an impact analysis. The Data Protection Agency has also issued these two municipalities an order to prepare an impact analysis within three months.

The other three municipalities have prepared impact analyses. The Data Protection Agency has reviewed them and assessed that none of them meet all the minimum requirements for an impact

analysis.

Additionally, the Data Protection Agency has examined the timing of the preparation of the impact analyses and taken into account that there has been uncertainty regarding the data responsibility for the processing of personal data in AULA. The municipalities and KOMBIT have thus been of the opinion that the data responsibility for the processing of personal data and the responsibility for conducting risk assessments and impact analyses lay with KOMBIT. However, the Data Protection Agency concluded during the oversight visit to KOMBIT in December 2019 that KOMBIT cannot be considered the data controller.

All three municipalities prepared the impact analyses only long after clarity about the data responsibility for the processing of personal data in AULA was established. Two of the municipalities even prepared the impact analyses only after the oversight had requested the material in connection with the initiation of the oversight, which is why the Data Protection Agency has expressed serious criticism towards these two municipalities. The Data Protection Agency has expressed criticism towards the third municipality.

#### Risk Assessment

All five municipalities have also received criticism or serious criticism regarding the part of the cases that concern the municipalities' risk assessment. The criticism relates to the documentation requirement to demonstrate that they have identified and mitigated the risks that the processing of personal data in AULA poses to the individuals concerned, ensuring an appropriate level of security. Additionally, the criticism concerns the lack of identification and implementation of relevant measures to ensure an appropriate level of security.

The Data Protection Agency has expressed serious criticism of two of the municipalities for not having submitted actual risk assessments. One municipality stated in January 2023 that they had not yet completed the initial work to identify relevant measures that could be implemented to ensure... to reduce the identified high risks associated with the processing of personal data in AULA. The other municipality referred to a number of appendices as documentation for the mitigating measures the municipality had taken to reduce the risk for the registered individuals. The remaining three municipalities have submitted risk assessments. However, the Data Protection Agency has criticized these municipalities for not sufficiently demonstrating that they have ensured an appropriate level of security.

Several municipalities have submitted material from KOMBIT, where a number of high risks associated with the use of AULA have been identified. The municipalities have responded differently to the material. Some municipalities have stated that they have adopted KOMBIT's risk assessment and have based their descriptions of the measures they have implemented to reduce these risks on it. One municipality indicates that they have reviewed the material from KOMBIT but concluded that it could not be immediately used as a basis for actual risk assessments. Other municipalities have conducted their own assessments, where some of the risks they have identified are assessed to pose a lower risk than what is indicated in KOMBIT's material—however, without sufficiently documenting the basis for this assessment.

#### **\*\*Risk of Misdelivery in AULA\*\***

The Data Protection Agency has noted that a large portion of the reports of breaches of personal data security in AULA that the agency receives concern the misdistribution of personal data to one or more incorrect recipients in AULA. This is also a risk that several municipalities have identified in their risk assessments. Several municipalities have implemented organizational measures to inform users about this risk when sending messages via AULA. Additionally, one of the municipalities has also implemented a change request in AULA that allows for the deletion and editing of sent content in messages.

Despite these measures, the Data Protection Agency continues to receive a number of breach reports from municipalities concerning misdistribution in AULA. It is generally the Data Protection Agency's view that data controllers who systematically use a technical functionality to send messages containing confidential and/or sensitive information should investigate whether it is possible to implement one or

more technical measures to reduce the risk of misdelivery. They should also explore options for designing the messaging function in a way that minimizes such risk.

In a letter to KL, KOMBIT, and the Agency for IT and Learning, the Data Protection Agency has recommended that KOMBIT, together with the data-controlling municipalities, conduct such an investigation. This recommendation will also be communicated in a letter to all municipalities in the country.

#### **\*\*Joint Impact Assessment and Code of Conduct\*\***

It is the Data Protection Agency's view that municipalities have the opportunity to prepare a joint impact assessment regarding data protection for their processing of personal data in AULA. This is based on the fact that the municipalities use the same type of system for the same processing activities of the same type of personal data, and that the municipalities' processing activities involve similar high risks. Furthermore, the system is provided by the same supplier.

In the letter to KL, KOMBIT, and the Agency for IT and Learning, the Data Protection Agency has therefore encouraged consideration across municipalities, and possibly in collaboration with KL and KOMBIT, to prepare a joint impact assessment regarding the municipalities' processing of personal data in AULA.

The Data Protection Agency has also recommended that KL, in collaboration with the municipalities and possibly KOMBIT, consider the possibility of developing a code of conduct in accordance with Article 40 of the General Data Protection Regulation regarding the municipalities' processing of personal data in AULA. The Data Protection Agency has noted that this consideration may also be relevant for other processing activities in the municipalities, where they use the same system for the same processing activities of the same types of personal data that involve similar high risks.

A code of conduct can provide correct and practical guidance on how to organize oneself in connection with one or more processing activities to comply with data protection rules. This could, for example, involve establishing procedures to be followed for a specific processing activity. A code of conduct would therefore be a useful tool to assist authorities that have subscribed to the code in complying with data protection rules. Although it facilitates compliance with the rules, it does not exempt the individual data controller from the obligations and tasks that rest with them as data controllers. This is particularly significant in situations where the data controller chooses to deviate from the assumptions in the common concepts and processes—for example, by using a system for other purposes.

"It is a significant and resource-intensive task for individual municipalities to conduct risk assessments and impact assessments that ensure the appropriate security measures. But it is necessary. AULA is a tool used in all municipalities for the same processing activities of the same type of personal data. We therefore encourage the municipalities—possibly in collaboration with KL and KOMBIT—to come together and ensure that citizens' information in AULA is adequately protected," says Signe Vestergård, special consultant at the Data Protection Agency.

#### **1. \*\*Written Supervision of Randers Municipality Regarding the IT System AULA\*\***

Randers Municipality is among the municipalities that the benefit of children, parents, and educators. The platform is intended to facilitate communication and collaboration among all parties involved in children's education and well-being.

#### **4. Background**

The Data Protection Authority (Datatilsynet) conducted an assessment of the risk evaluation performed by Randers Municipality regarding the processing of personal data in AULA. The authority's oversight is based on the General Data Protection Regulation (GDPR) and the Danish Data Protection Act. The assessment aimed to ensure that Randers Municipality has adequately identified and mitigated risks associated with personal data processing.

#### **5. Findings**

The Data Protection Authority finds that Randers Municipality has not sufficiently demonstrated whether and to what extent there are high risks associated with the municipality's processing of

personal data in AULA. Consequently, the authority concludes that Randers Municipality has not shown that it has identified and assessed the significant risks that the processing of personal data in AULA poses to the data subjects.

Furthermore, the Data Protection Authority finds that Randers Municipality has not demonstrated that the measures implemented to reduce the risks associated with the processing of personal data in AULA are adequate to lower the risk to a low level. It is therefore the authority's assessment that Randers Municipality has not sufficiently proven that it has ensured a security level appropriate to the risks posed by the processing of personal data in AULA.

The Data Protection Authority criticizes Randers Municipality for not processing personal data in accordance with Article 5(2) in conjunction with Article 1(f) and Article 24(1) in conjunction with Article 32(1) of the GDPR.

Additionally, the Data Protection Authority assesses that Randers Municipality has not conducted a comprehensive impact assessment as required by Article 35(1) of the GDPR, as the submitted impact assessment does not meet the minimum requirements set out in Article 35(7)(a), (c), and (d) of the regulation.

The authority further finds that Randers Municipality, by preparing an impact assessment for the processing of personal data in AULA nearly two years after it became clear that the municipality is the data controller for processing personal data in a solution that involves a high risk for the data subjects, has acted contrary to Article 35(1) of the GDPR.

The Data Protection Authority considers it serious that the impact assessment appears to have been prepared only after the authority requested the material as part of the written oversight in the area.

On this basis, the Data Protection Authority finds grounds to express serious criticism that Randers Municipality's processing of personal data has not occurred in accordance with Article 35(1) of the regulation.

## 6. Case Presentation

The Data Protection Authority notified Randers Municipality of the oversight by letter dated October 15, 2021. In this connection, the authority requested the municipality to submit the following:

- The risk assessments that form the basis for the evaluation of what security is deemed appropriate for the processing of personal data in AULA, as well as a description of the general security models in the application.
- Copies of all versions of any impact assessments that have been prepared.
- A review of considerations regarding the use of Article 25 of the GDPR in connection with the procurement and development of AULA.
- A review of authorization and access control models.

Randers Municipality submitted a statement regarding the case along with a number of appendices, including the municipality's risk assessment and impact assessment for AULA on November 5, 2021.

Based on the statements from the six selected municipalities, the Data Protection Authority has chosen to limit the focus of the oversight to questions regarding risk assessment and impact assessment. It should be emphasized that the Data Protection Authority has not, in connection with this oversight, taken a position on whether Randers Municipality's processing of personal data in AULA complies with Article 25 of the GDPR regarding data protection by design and by default, or whether the municipality's authorization and access control models comply with Article 32 of the GDPR.

The Data Protection Authority subsequently requested Randers Municipality to submit dated copies of the municipality's updated material from 2022 by email dated December 6, 2022. Randers Municipality submitted updated material to the Data Protection Authority on December 20, 2022.

### 6.1. General Information on Decision and Development of AULA

The Danish Municipalities' Association (KL) states on their website that the municipal procurement of AULA is part of the User Portal Initiative, which is a political initiative from 2013. It further states that

AULA aims to support communication and thereby collaboration regarding children's learning and well-being in a secure and user-friendly manner. KL also indicates that all 98 municipalities in Denmark collaborated in 2016 on a joint tender for a collaboration platform – the later AULA – for the benefit of children, parents, and educators. The platform is intended to facilitate communication and collaboration among all parties involved in children's education and well-being.

**\*\*School Area.\*\*** AULA was put out to tender by the municipalities' IT community, KOMBIT A/S (hereinafter referred to as KOMBIT), at the beginning of 2017, and the choice fell on the supplier Netcompany – IT and Business Consulting, which has since developed AULA in collaboration with the companies Frog, EduLab, and Advice. KOMBIT provides information about AULA on the website [aulainfo.dk](http://aulainfo.dk). It appears from this that the majority of public schools began using AULA in 2019 and daycare facilities in the winter of 2020/2021.[4] The Data Protection Agency assumes that the individual municipalities are independently data controllers for their processing of personal data in AULA, and that KOMBIT, which is the municipalities' data processor, has entered into a data processing agreement with Netcompany, which is thus a sub-processor.[5]

### **\*\*3.2. Randers Municipality's Comments\*\***

#### **\*\*3.2.1. Risk Assessment\*\***

Randers Municipality has submitted an Excel sheet containing the municipality's risk assessment for the processing of personal data in AULA. In this context, Randers Municipality has stated that the first version showed that the security level was insufficient in some areas, and that Randers Municipality has been continuously working on measures in AULA. It appears from the submitted risk assessment that it was prepared on April 4, 2020, and that it was last amended on October 28, 2021. It further appears that the risk assessment was prepared based on KOMBIT's own risk assessment.

The risk assessment includes guidance for completing the risk assessment form. It states that a threat must be selected from a list that is assessed to pose a risk. Subsequently, it must be assessed what impact the threat may have on confidentiality, integrity, and availability. Regarding confidentiality, it must be indicated whether it concerns public information, confidential information, or secret information. The likelihood of the specific threat must then be indicated on a scale from 1-6, and the frequency must be assessed. The consequence for Randers Municipality must then be indicated on a scale from 1-6, and the risk must be calculated. It is then stated that a consequence assessment for the rights of the data subjects must also be made, where the consequence must be indicated on a scale from 1-6, and it must be described why the consequence is assessed as such. A probability must then be indicated on a scale from 1-6, as well as the frequency. A risk score for the data subjects is then calculated. It is described in the guidance that for a risk score that is red or yellow, the new measures that are implemented must be described, and a new assessment for risk and a new assessment for probability must be made.

Upon reviewing Randers Municipality's risk assessment based on the described method, the Data Protection Agency can ascertain that Randers Municipality has assessed 19 threats, and that there is one yellow risk score, while the rest are green. The Data Protection Agency thus assumes that Randers Municipality assesses that there are no high risks for the data subjects associated with the processing of personal data in AULA.

The threat that has been assessed to pose a yellow risk score is as follows:

“Incorrect handling of sensitive personal data by an authorized user. Unintentional disclosure of sensitive personal data by an authorized user.”

In relation to six of the 19 threats, the following new measures have been described that are being implemented:

In relation to the threat:

“Administrative rights. Too many employees have superuser/administrative rights to the business system, e.g., due to inadequate possibilities for rights management.” the following measure is noted: “A approval process has been initiated, which involves an additional person.”

In relation to the threat: “Incorrect handling of sensitive personal data by an authorized user.

Unintentional disclosure of sensitive personal data by an authorized user. The significance or consequences of this threat may be amplified based on the user type. For example, by an employee with administrative access" the following measure is noted:

"It is experienced that the problem occurs in connection with email transmissions. It is possible to retract an email in case of error. The user of the system has been informed about this. A comprehensive catalog with procedure descriptions for handling errors is being created."

In relation to the threat: "Lack of authorization control. Access of former employees is not removed, and can thus be used to compromise the asset/system" the following measure is noted:

"Work is being initiated to ensure automatic user creation and user termination, based on information from the payroll system. There is a procedure for authorization control."

In relation to the threat: "Unauthorized access to legitimate user information, or misuse of existing accesses. Unauthorized access to a legitimate user's log-on information, including username and password. Can occur in several ways: Leak of user information, insecure storage of user information, or brute force attacks. This incident also covers unauthorized misuse of accesses that are either too broad or should be closed" the following measure is noted:

"Guidance material is provided during the onboarding of new employees. The material informs each user about the correct use of AULA."

In relation to the threat: "Log errors. Logging is not set up correctly, which may compromise confidentiality without detection," the following measure is noted:

"There is very limited ability to manage one's own log information. Logging on the system is ordered from the supplier. Errors by the supplier regarding logging can have an impact."

In relation to the threat: "Lack of support for save/delete function. The system does not support rule-based saving or deletion," the following measure is noted:

"A procedure has been developed regarding how long a document can remain in an open state. Checks can be performed to ensure compliance with the rule."

The Data Protection Agency can deduce from the risk assessment that Randers Municipality assesses that the new measures reduce the risk, and that Randers Municipality accepts the residual risks, which, based on a new assessment of consequence and likelihood after the implemented measures, are all green.

On December 20, 2022, Randers Municipality stated that in order to work more structurally with, among other things, risk assessments and impact analyses, Randers Municipality is in the process of implementing processing activities and associated risk assessments in a suitable system. In connection with the implementation, risk assessments, including the risk assessment for AULA, will be updated. It is stated that these processing activities have been recommended by KL's partnership on information security, of which Randers Municipality is a part.

Furthermore, Randers Municipality has stated that KOMBIT sent revised risk assessments of AULA to the municipalities in September 2021, which consist of risk assessments for 12 modules and five data processors. In this context, Randers Municipality has stated that it is the municipality's assessment that the overall threat picture still corresponds to the previously sent risk assessment.

The relevant risk assessments from KOMBIT have not been sent by the municipality, but the Data Protection Agency has received these from several of the other municipalities that the Data Protection Agency has selected to supervise regarding AULA.

Randers Municipality has submitted the municipality's impact analysis as well as two versions of drafts/templates for the impact analysis of the processing of personal data in AULA from KOMBIT. It appears from Randers Municipality's impact analysis that the municipality received KOMBIT's impact analysis on January 28, 2020, and that the municipality reviewed and adjusted the impact analysis in relation to Randers Municipality on October 28, 2021. The Data Protection Agency assumes that Randers Municipality's impact analysis is based on the first version of the drafts for impact analyses sent by KOMBIT.

The Data Protection Agency can confirm that the two versions of drafts/templates for the impact analysis of AULA from KOMBIT contain text that KOMBIT has prepared and sections where the individual municipalities must fill out the impact analysis. In the first version of KOMBIT's draft/template, it is stated that KOMBIT has identified 18 incidents that are assessed to pose high risks in AULA (Message, Search, Gallery, Profile, Secure file sharing, Administration, Posts, Login, Calendar). It appears from the revised version of the draft/template that KOMBIT has identified 27 incidents that are assessed to pose high risks in the same modules in AULA and in relation to five data processors (Administration of users and groups, Login and user information, Communication and collaboration in primary schools, Communication and collaboration in daycare, and Sharing of information with other IT solutions).

These 18 and 27 incidents in the various modules and data processors constitute the following five types of incidents:

"Failure of access control or errors in this" (Unauthorized access to the system and data due to insufficient enforcement of access control)

"Mismanagement of personal data in the system/solution, carried out by an authorized user" (Unintentional disclosure of personal data in the application, carried out by an authorized user)

"Incorrect handling due to incorrect or missing implementation of data classification in the solution" (Leak of sensitive data due to incorrect (too low) or missing data classification)

"Incorrect accesses due to unclear or missing policies" (Incorrect user or system access granted due to unclear access policies)

"Use of inadequately protected username and password" (Children's storage of username and password is often careless, as they write information on a note or device. Particularly for younger children. This can allow for malicious misuse of a student's user access in AULA)

In Randers Municipality's impact analysis, the information about these high risks has been deleted in the section on identification and evaluation. Instead, it is referred to that the municipality's risk assessment can be found in an Excel sheet with various tabs. The Data Protection Agency assumes that this is the Excel sheet with the risk assessment that the agency has received from Randers Municipality.

Randers Municipality describes in their impact analysis that the risk assessment is based on a threat catalog with over 45 different incidents, where the likelihood of the incident has been assessed. the consequences of the events being assessed. In the section on the identification of mitigating measures in Randers Municipality's impact assessment, the following is stated:

"According to the risk assessment, the greatest threat currently arises when human errors occur in connection with incorrect delivery of messages. Technical measures have already been implemented to avoid this in the development of Aula. A clearer 'reply sender' button has been implemented instead of the 'reply all' button in the messaging function in Aula. It is still too early to assess the extent to which this alleviates the problem. In addition, clearer guidelines are being provided by Randers Municipality to the staff to minimize cases of incorrect deliveries, and any errors will be promptly corrected by deleting the message."

The following measures have been listed to manage the identified risks as outlined in the risk assessment in the Excel sheet:

"User creation and deletion via payroll system"

"Comprehensive catalog of procedure descriptions, including error handling"

"Implementation of a process for the use of additional 'eyes' for authorization allocation."

In this context, it is noted that the effect of these measures is that the three risks for which the measures have been implemented to reduce have been reduced to a residual risk that is low. The three risks are numbered from one to three, but it is not specified which risks are being referred to. It is indicated that none of the three measures have been implemented. In section 10 of the impact assessment, where an implementation plan is established, it is stated that "User creation and deletion via payroll system" is expected to be implemented by mid-2022, "Comprehensive catalog of procedure descriptions, including error handling" is expected to be completed by early 2022, and "Implementation

of a process for the use of additional 'eyes' for authorization allocation" will be initiated in early 2022. Randers Municipality has also referred to an annex titled "Aula – latest changes and initiatives in Randers Municipality," which outlines how Randers Municipality has worked with the risks identified in the material sent by KOMBIT as high (red). It is noted in the annex that it was updated on December 12, 2022. The annex describes technical and organizational measures concerning 23 risks in eight modules in AULA (Login, Profile, Secure file sharing, Calendar, Search, Messages, Come-go, and Posts). As examples, the Data Protection Authority can highlight the following measures:

A password policy has been introduced in the primary school.

Rights management forms have been introduced, where each school/daycare is responsible for reviewing rights in AULA, both for staff and parents. This is done semi-annually, and municipal AULA administrators will conduct random checks.

Access to AULA as an employee is governed by their affiliation with the school. If the employee's affiliation with the school ceases, they will automatically lose access to AULA.

A framework has been developed regarding which types of users should have which rights.

Employees in institutions and schools in Randers Municipality are periodically informed about how to process, store, and handle personal data and are instructed on how and what to write and not write in posts/groups/messages.

Randers Municipality has a data policy that outlines how schools and daycare centers handle personal data in AULA.

Employees have been made aware in an introduction to secure file sharing in AULA that secure files are only shared with personnel who have a work-related need for access, and that the right to retrieve secure files to their own device is only granted to pedagogical staff in daycare centers as well as leaders and school secretaries in schools.

Templates and forms are stored in Aula secure file sharing, so these documents are automatically created as secure files linked to each child, and thus only the relevant employees have rights to the files according to the rights management procedure.

It is possible for the sender to delete and edit sent content in messages in AULA. Randers Municipality states in this context that this is a technical measure that allows for limiting the dissemination of content that has been sent incorrectly. Randers Municipality informs that this update was made in December 2022.

Messages can be marked as sensitive, and the sender and recipient can also add this marking after sending/receiving a message.

Randers Municipality has further stated that KOMBIT is continuously developing the functions in AULA, among other things, with a view to processing security. In this context, Randers Municipality states that municipalities can submit functional change requests via AULA's support function, which Randers Municipality actively does. As an example, Randers Municipality mentioned an update in AULA from December 2022, where it is possible for the sender of a message in AULA to delete and edit sent content. The municipality notes in this context that it is a technical measure that allows for limiting the dissemination of content that has been sent incorrectly.

### 3.2.2. Impact Assessment

As mentioned above in section 3.2.1, Randers Municipality has submitted their impact assessment regarding the processing of personal data in AULA, which has been prepared based on KOMBIT's draft/template.

The Data Protection Authority assumes that the impact assessment was prepared on October 28, 2021, based on KOMBIT's draft/template, which the municipality received on January 28, 2020.

It is stated in section 2 of the impact assessment regarding...

**\*\*Background\*\***

The consequence analysis has been prepared based on KOMBIT's draft but adjusted according to the reality of Randers Municipality. In this context, it is noted that KOMBIT, as an advisor and purchaser for all 98 municipalities, has assisted the municipalities in preparing a consequence analysis for the system. Randers Municipality subsequently states that the municipality has assessed that there is a need to supplement the consequence analysis for the municipality-specific processing activities.



Furthermore, it is stated that the consequence analysis should have been prepared prior to the implementation and commissioning of the system based on the risk picture from the risk assessments for the use of AULA. The Data Protection Authority's supervisory visit to KOMBIT in December 2019 is also mentioned in the section.

The first section of the consequence analysis contains a summary, which indicates that the consequence analysis shows, according to the risk assessment, that the greatest threat arises when human errors occur in connection with the erroneous delivery of messages. It is further stated that the Data Protection Authority does not need to be consulted pursuant to Article 36, paragraph 1 of the Data Protection Regulation, as the consequence analysis does not indicate that the processing of personal data in the solution will lead to a high risk for the data subjects in the absence of measures.

The section also contains the following regarding matters pointed out by the municipality's data protection advisor: "Randers Municipality's data protection advisor points out that this analysis should have been conducted before the implementation and commissioning of the system. Randers Municipality, as the data controller, must ensure that appropriate security measures are in place before the system is put into use. The data protection advisor emphasizes that AULA is a larger system with many registered individuals, many users, and a lot of data, and that information about children is processed. A risk assessment has been prepared, and continuous work has been done to improve security measures, where Randers Municipality's data protection advisor, information security consultant, and system administrator for AULA have a close collaboration."

In section 3 of the consequence analysis, the process for conducting the consequence analysis is described, including the method and the involvement of the data subjects. In the section on the involvement of the data subjects, it is stated, among other things, that representatives of the data subjects have been involved and that their views have been heard regarding the planned processing. In this context, it is noted that the following have been involved: the Agency for IT and Learning, employees, parents, municipalities (in relation to requirement specifications), more than 15 data protection advisors from various municipalities, the association School & Parents, BUPL, among others.

Section 4 of the consequence analysis contains a description of the planned processing. The section describes various aspects of the nature, scope, context, and purpose of the processing. The following is stated regarding the purpose of processing personal data in AULA: "The purpose of processing personal data in AULA is to provide a communication platform and thereby give access to the processing and storage of data for daily work concerning children in daycare and students in the municipality's schools in a system that can support communication and learning processes in primary schools and in the daycare area. Thus, there are no cases, decisions, profiling, personnel administration, etc., taking place in AULA."

Section 5 of the consequence analysis is titled "Assessment of Necessity and Proportionality." The section contains descriptions related to the principles of legality, fairness, and transparency, the principle of purpose limitation, the principle of data minimization, the principle of accuracy, the principle of storage limitation, processing security, the rights of the data subjects, the relationship with data processors, and the transfer of personal data to third countries and international organizations.

Randers Municipality has, among other things, addressed the legal basis for the processing activities in this section, whether the purpose can be achieved using anonymized aggregated or pseudonymized data, how it is ensured that the personal data is accurate, and how compliance with the various rights is ensured. In the section on the principle of storage limitation, reference is made to a policy for deletion rules and deletion procedures in AULA, which is available on the website [aulainfo.dk](http://aulainfo.dk).

Additionally, Randers Municipality's use of data processors and sub-processors in relation to the use of AULA is described. In this context, it is described how compliance with the requirements for data processors in the Data Protection Regulation is ensured. Regarding transfers to third countries, the consequence analysis states that personal data is not transferred to third countries or international organizations. In this context, the municipality refers to a declaration from Amazon Web Services

(hereinafter AWS) and Netcompany regarding the assurance that personal data is not transferred to third countries.

Section 6 of the consequence analysis concerns the identification and evaluation of risks, and section 7 concerns the identification of measures to address the identified risks. These sections are discussed in more detail under point 3.2.1 above.

In section 9 of the consequence analysis, it is indicated by checking a pre-filled box that management has approved the consequence analysis and that processing can then begin, provided that the mitigating measures described in the consequence analysis are implemented.

Finally, it is stated in section 11 of the consequence analysis...

**\*\*on the maintenance/update of the impact assessment,\*\***

that Randers Municipality shall regularly review the impact assessment, cf. Article 35, paragraph 11, and that this must occur at a minimum when there is a change in the risk associated with the processing activity.

**\*\*3.3. Reported breaches of personal data security concerning AULA\*\***

The background for the Danish Data Protection Agency's initial decision to supervise municipalities with a particular focus on the technical and organizational security measures observed to meet the requirement for an appropriate level of security for the processing in AULA is that the Agency has seen (and continues to see) a number of reported breaches of personal data security in connection with the processing of personal data in AULA.

In AULA, personal data is processed, including confidential and sensitive personal data about vulnerable registered individuals, which includes children. Furthermore, the system's users are often individuals who do not primarily work with data protection (including educators, pedagogical staff, as well as students and parents), which, in the Agency's view – in light of the many reported breaches from the vast majority of the country's municipalities – may imply that stricter requirements should be imposed on the data controllers' observance of both technical and organizational measures, cf. Article 32, as well as mitigating measures for compliance with the regulation's Article 25.

A large portion of these reports of breaches of personal data security in AULA concerns instances where personal data has been sent to one or more incorrect recipients in AULA. For example, where a message or secure file about a child has been sent to another child's parents, or where a message has been mistakenly sent to a group of recipients instead of a specific recipient. The Data Protection Agency has also seen cases where, when sending documents to one or more parents, an incorrect document containing information about another child has been attached. Thus, there have been several unintended disclosures of personal data about children in AULA, including descriptions of children's concentration difficulties, settings for pedagogical-psychological assessments, information about dyslexia, school statements, as well as action plans and assessments regarding educational readiness.

By searching in the Data Protection Agency's ESDH system, the Agency can ascertain that it has received 23 reports of breaches of personal data security from Randers Municipality under the data protection regulation's Article 33, where AULA is mentioned in the report. The majority of the reports concern incidents where a message in AULA has been sent to one or more incorrect recipients. There are both cases where a message containing confidential information about a student has been sent to another student's parents, and where a message has been sent to an entire group of parents/a whole class's parents instead of the relevant student's parents. Additionally, there are examples of incidents where parents and staff in a message thread reply to all in the thread instead of replying directly to the sender, resulting in everyone in the thread receiving confidential information about a child.

Furthermore, there is an example of an incident where an incorrect file containing information about another student has been sent to some parents.

Moreover, the Data Protection Agency has received reports regarding unauthorized access to information about whether a contact person has custody of a child and content in the "secure file sharing" module.

**\*\*4. Justification for the Data Protection Agency's decision\*\***

#### **\*\*4.1. Risk assessment\*\***

The Data Protection Agency assumes that the submitted Excel sheet constitutes Randers Municipality's risk assessment for the processing of personal data in AULA, and that the risk assessment has been prepared based on KOMBIT's own risk assessment.

##### **\*\*4.1.1. Relevant rules\*\***

The General Data Protection Regulation requires at several points that a data controller addresses the risk to the rights and freedoms of the data subjects and can document the considerations and conclusions this has led to.

It follows directly from the provisions in Articles 5, paragraph 1, letter f, 24, 25, 32, 33, 34, 35, 36, and 39, that the data controller must address the risk to the rights and freedoms of the data subjects.

Furthermore, it follows from both Article 5, paragraph 2, regarding the principles in Article 5, paragraph 1, and Article 24 regarding compliance with the entire regulation, that a data controller must be able to demonstrate compliance with data protection rules.

Among other things, Articles 25, 35, and 36 require that considerations regarding the involved risks to the rights of the data subjects must be made before the processing begins.

It follows from the General Data Protection Regulation's Article 5, paragraph 1, letter f, that personal data must be processed in a manner that ensures adequate security for the relevant personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures.

The data controller must also be able to demonstrate that the fundamental principles are adhered to, which follows from the General Data Protection Regulation's Article 5, paragraph 2.

According to the General Data Protection Regulation's Article 32, paragraph 1, the data controller must take appropriate technical and organizational measures to ensure a security level that is appropriate to the risks associated with the data controller's processing of personal data.

It follows from the General Data Protection Regulation's Article 24, paragraph 1, that a data controller must implement appropriate technical and organizational measures to ensure and to be able to demonstrate that the processing is in compliance with the regulation.

The data controller has an obligation to identify the risks that the data controller's...

##### **\*\*4.1.1. General Requirements for Risk Assessment\*\***

The processing constitutes a risk for the data subjects and aims to ensure that appropriate security measures are implemented to protect the data subjects against these risks. The data controller must also be able to demonstrate that personal data is processed in a manner that ensures adequate security for the individuals to whom the data relates. In order for the supervisory authority to assess whether an appropriate level of security has been ensured, it must be documented and explained which risks the data controller has identified and what mitigating measures have been taken to reduce these risks.

##### **\*\*4.1.2. General Requirements for Risk Assessment\*\***

The Data Protection Authority notes that the data protection regulation does not specify how detailed the risk assessment should be. It is the opinion of the Data Protection Authority that the data controller must establish an appropriate level considering the risks that are relevant to the data controller's processing of personal data.

If a supplier, data processor, or available analyses, etc., establishes or indicates specific risk scenarios, it is the opinion of the Data Protection Authority that data controllers should take these assessments into account, especially when processing activities in a system are deemed to involve high risks for the data subjects. At a minimum, there must be a substantiated assessment of why the situation is not relevant in the processing of personal data that occurs with the data controller.

It is not explicitly stated anywhere in the data protection regulation how the documentation should look, what the specific content should be, or what the frequency of updating and revision should be. The Data Protection Authority's opinion is that the documentation obligation means that the supervisory authority – from the total material that the data controller can present – can make an assessment of

whether the processing is in accordance with the data protection regulation. It should thus be evident from the presented material how and on what basis the data protection considerations have been made. This includes, among other things, the legality of the processing and the ability to ensure compliance with the rights of the data subjects, adherence to the data protection principles, and ensuring an appropriate level of security.

Furthermore, it should be clear what considerations, choices, and omissions have been made to ensure that the processing of the information is in accordance with the data protection regulation. In this context, it should be possible to timestamp when and with what content relevant considerations and actions have taken place.

It is the opinion of the Data Protection Authority that a risk assessment should include an evaluation of the consequences (e.g., high, medium, low) for the data subjects in the event of loss of confidentiality, availability, and integrity. Subsequently, the risk assessment should identify which threats exist for the loss of confidentiality, availability, and integrity, as well as the likelihood (e.g., high, medium, low) that the threat will materialize. Finally, the risk assessment should map the existing security measures and their contribution to reducing the risk. On this basis, the data controllers can assess the risk and determine whether it is an acceptable risk or whether additional measures should be implemented. By addressing these elements in a risk assessment, the data controllers can document how they have assessed the risk for the data subjects regarding the relevant processing activities, as well as on what basis they believe that the implemented measures have reduced the risk.

#### **\*\*4.1.3. Randers Municipality's Identification and Assessment of Risks\*\***

Following a review of Randers Municipality's risk assessment, the Data Protection Authority concludes that Randers Municipality has not identified high risks associated with the processing of personal data in AULA in their risk assessment. In this context, the Data Protection Authority notes that Randers Municipality assesses that the erroneous handling of information by authorized users in AULA, which leads to unintended disclosure of personal data, constitutes a medium (yellow) risk, and that the remaining identified risks are low (green).

In this regard, Randers Municipality has assessed, in relation to 19 threats, the degree of impact that the threat may have on confidentiality, integrity, and availability. Additionally, the risk assessment includes an evaluation on a scale from 1-6 of the likelihood that the threat will materialize and what the consequence for the data subjects is. Based on this, the risk for the data subjects has been calculated.

The Data Protection Authority can ascertain that Randers Municipality has assessed that the consequence is "serious" (4) for two threats. For the remaining 17 threats, the consequence has been assessed as "significant" (3), "moderate" (2), or "limited" (1). None of the threats are assessed by Randers as having a consequence that is "critical" (5) or "catastrophic" (6) if realized. The assessment does not clarify why the consequence has been evaluated in this manner.

The Data Protection Authority can confirm, by comparing Randers Municipality's risk assessment with the submitted templates/drafts for impact analyses from KOMBIT, that Randers Municipality, in their identification of risks, prior to any measures being taken, has assessed that some risks constitute a low or medium risk, whereas KOMBIT has assessed these risks as high.

As an example, the Data Protection Authority can mention the erroneous handling of personal data carried out by a...

**\*\*Authorized User**, where there is an unintentional disclosure of personal data, where KOMBIT assesses that it constitutes a high risk, and Randers Municipality assesses that it constitutes a medium risk. In this regard, it is noted that Randers Municipality assesses that the consequence is "serious" (4), and that the probability is "likely" (4), whereas KOMBIT assesses that the consequence is "devastating (very critical)", and that the probability is "expected". Another example is the lack of authorization control and insufficient or deficient organizational security measures around the system, e.g., ambiguity regarding roles and responsibilities. Randers Municipality assesses that these threats constitute a low risk, whereas KOMBIT assesses that incorrect accesses due to lacking or unclear

policies constitute a high risk. Randers Municipality has stated that KOMBIT sent revised risk assessments to the municipalities in September 2021, but that it is the municipality's assessment that the overall threat picture still corresponds to the previously sent risk assessment. However, Randers Municipality does not appear to have explained why the stated risk scenarios entail a lower risk in Randers Municipality than what is indicated in KOMBIT's risk assessment in the template/draft for the consequence analysis. Thus, it has not been explained why Randers Municipality assesses that the consequence is not as serious as KOMBIT has assessed, nor why it is not as likely that the threat will materialize, as KOMBIT assesses. However, Randers Municipality has described in a separate annex how the municipality has worked with the risks that were identified as high (red) in the material sent by KOMBIT. In the annex, the municipality has described technical and organizational measures that are or will be implemented in relation to 23 risks across eight modules in AULA. Randers Municipality thus appears to have addressed these risks. The Data Protection Authority has, however, understood from Randers Municipality's statements that the material from KOMBIT has not prompted Randers Municipality to revise their risk assessment.

The Data Protection Authority finds on this basis that Randers Municipality has not demonstrated whether and to what extent there are high risks associated with the municipality's processing of personal data in AULA. Therefore, the Data Protection Authority finds that Randers has not shown that they have identified and assessed the most significant risks that the municipality's processing of personal data in AULA poses to the registered individuals.

#### **\*\*4.1.4. Randers Municipality's Description of Security Measures\*\***

In Randers Municipality's risk assessment, measures that are or will be implemented to reduce the identified risks are described in relation to six of the 19 threats. The Data Protection Authority has, through an overall review of the described measures in the risk assessment and in the separate annex with the described measures mentioned above, found that the measures appear to be relevant for reducing the various risks. However, it is not clearly stated whether the different measures are sufficient to reduce the respective risks to a low level. As listed under point 3.2.1. above, Randers Municipality has, for example, indicated as a measure regarding the risk of unintentional disclosure of personal data due to user error, that it is possible to retract emails in case of mistakes, and that a comprehensive catalog of procedure descriptions for handling user errors will be created. Randers Municipality has also informed the Authority that the municipality, through AULA's support function, has submitted a change request to KOMBIT to make it possible for the sender to delete and edit sent content in messages. According to the separate annex with the description of a number of measures, this has been implemented, so that since December 2022 it has been possible to delete or edit sent content in messages in AULA. In the separate annex, where a number of measures are described, it is also stated that messages with sensitive content are marked as sensitive, and that employees are instructed on how and what they should write and not write in posts, groups, and messages. It appears from the risk assessment that the consequence has been reduced to "limited" (1) from being "serious" (4). The probability is still indicated as likely (4), as was the case in the assessment before the implemented measures. On this basis, Randers Municipality assesses that the risk has been reduced to low (4) from being medium (16).

In this regard, the Data Protection Authority notes that the Authority continues to regularly receive reports of breaches of personal data security in AULA from the country's municipalities, including incidents where information is unintentionally disclosed to unauthorized parties in, for example, messages. The Data Protection Authority can ascertain that since Randers Municipality's latest update of their risk assessment on October 28, 2021, it has received 12 reports of breaches of personal data security from Randers Municipality regarding incidents where a user has mistakenly disclosed personal data to incorrect recipients. Two of the reports concern incidents where parents mistakenly send a message in a message thread to everyone in the thread instead of directly to the employee who sent a message in the thread. The remaining reports concern incidents where employees mistakenly disclose personal data to incorrect recipients in AULA's messaging module.

Furthermore, the Data Protection Authority can ascertain that since December 2022, when it has been

possible to delete and edit sent content in messages, it has received five reports regarding unintentional disclosure of personal data in AULA based on...\*\*  
of user error. In one of the reviews, it is described that an administrator retracts the message containing health information 2.5 hours after the incident, but the municipality can ascertain that 15 out of the 40 individuals who mistakenly received the message have read it.  
The Data Protection Agency finds, on this basis, that Randers Municipality has not demonstrated that the implemented measures have ensured that the risk of unintentional disclosure of personal data due to user error has been reduced to a low level.

4.1.5. Specifically regarding the risk of erroneous transmission in AULA's messaging module  
It is generally the opinion of the Data Protection Agency that data controllers who systematically use a technical functionality to send messages containing, among other things, confidential and/or sensitive information should investigate whether it is possible to implement one or more technical measures to reduce the risk of erroneous transmission, or whether it is possible to design the messaging function in a way that minimizes such risk.

On this basis, the Data Protection Agency recommends that Randers Municipality, together with KOMBIT and the other data-controlling municipalities, conduct such an investigation. This is particularly relevant considering that AULA's users are often individuals who do not primarily work with data protection (teachers, educational staff, and parents), which, in the agency's opinion – in light of the many reported breaches – may imply that stricter requirements should be placed on the data controller's observance of both technical and organizational measures according to Article 32.  
In this context, the agency can mention that it has found that AULA's messaging module is designed in such a way that in messages sent to multiple recipients, it is most obvious to reply to all individuals in the message thread. There is a less visible field where it is possible to reply directly to the sender of the message. However, in the field where the user replies to all in the message thread, there is information about how many individuals the user is replying to. Such a design of the messaging function, in the opinion of the Data Protection Agency, entails a risk that users of AULA inadvertently send a message to all recipients in a message thread instead of solely to the sender of the message. In this regard, there is a risk that there is an unjustified disclosure of (sensitive or confidential) personal data to incorrect recipients.

Furthermore, the Data Protection Agency has found that recipient suggestions are automatically generated when the user begins to type in the recipient field "To." In this context, both employees, children, and parents are suggested as recipients. This entails, in the opinion of the Data Protection Agency, a risk that users select one or more incorrect recipients from the list of suggested recipients, or that they select, for example, all suggested parents whose first name or last name contains the entered letters, instead of one specific recipient.

#### 4.1.6. Overall assessment regarding risk assessment

After an overall assessment, the Data Protection Agency finds that Randers Municipality has not demonstrated whether and to what extent there are high risks associated with the municipality's processing of personal data in AULA. Therefore, the Data Protection Agency finds that Randers has not shown that it has identified and assessed the most significant risks that the municipality's processing of personal data in AULA poses to the data subjects.

Additionally, the Data Protection Agency finds that Randers Municipality has not demonstrated that the measures implemented to reduce the risk associated with the processing of personal data in AULA are sufficient to lower the risk to a low level. It is thus the assessment of the Data Protection Agency that Randers Municipality has not sufficiently demonstrated that it has ensured a level of security that is appropriate to the risks posed by the processing of personal data in AULA.

The Data Protection Agency therefore criticizes that Randers Municipality's processing of personal data has not been conducted in accordance with the General Data Protection Regulation's Article 5, paragraph 2, in conjunction with paragraph 1, letter f, and Article 24, paragraph 1, in conjunction with Article 32, paragraph 1.

The Data Protection Agency has noted that Randers Municipality will update the risk assessment for AULA in connection with the municipality's implementation of a system for more structured work with,

among other things, risk assessments and impact analyses. The Data Protection Agency recommends that Randers Municipality takes the above into consideration in this context.

In choosing a response, the Data Protection Agency has emphasized that Randers Municipality in April 2020 – and thus within six months after it became clear that individual municipalities are data controllers for their processing of personal data in AULA – conducted a risk assessment of AULA, where the municipality has worked on and attempted to reduce the identified risks. In this context, the Data Protection Agency has emphasized that the municipality has implemented both organizational measures and submitted functional change requests to KOMBIT, which have subsequently been implemented in the solution. Randers Municipality is also seen in the separate annex to have addressed whether, based on KOMBIT's risk assessment, it was necessary to implement additional measures.

However, the Data Protection Agency finds that Randers Municipality's risk assessment is not sufficiently detailed. This is based on the fact that Randers Municipality has not explained why the cited risk scenarios in KOMBIT's risk assessment in the template/draft for the impact analysis entail a lower risk in Randers Municipality than what KOMBIT has assessed. Furthermore, Randers Municipality has not addressed whether the breaches of personal data security in AULA that have occurred in Randers Municipality warrant a different assessment of the risk. It does not appear from the risk assessment why

the consequences have been assessed as they are.

## 4.2. Consequence Analysis

### 4.2.1. Requirement for Consequence Analysis

It follows from Article 35, paragraph 1 of the Data Protection Regulation that if a type of processing, particularly through the use of new technologies and by virtue of its nature, scope, context, and purposes, is likely to result in a high risk to the rights and freedoms of natural persons, the data controller shall carry out an analysis of the intended processing activities' consequences for the protection of personal data prior to the processing. A single analysis may encompass several similar processing activities that involve similar high risks.

In the guidelines on consequence analysis regarding data protection from the Article 29 Working Party (now the European Data Protection Board, EDPB)[7], criteria have been established to help identify the processing activities that will require a consequence analysis. According to the guidelines, a data controller can generally assume that processing which meets two of the criteria must be subject to a consequence analysis regarding data protection.

The processing of personal data in AULA meets two of these criteria, as sensitive and confidential personal data about vulnerable data subjects, including children, is processed. Furthermore, it concerns a system used for collaboration and communication between schools/daycare institutions and children and their parents. In the system, personal data is exchanged in messages, among other things, and there are many users associated with the system. The Data Protection Authority believes that this communication entails a risk that, due to human errors, personal data may be inadvertently disclosed to incorrect users. This is particularly noted given that the users consist of both municipal employees as well as children and their parents, and that – regardless of guidance – human errors will occur for which there are no immediate mitigating measures.

Generally, based on the types of information processed in AULA, the volume of information, the number of transactions (exchange of information in connection with communication), and the diversity of users in composition, there is not only a potential risk of the risk scenario occurring but also a real one.

The consequences for the rights of the data subjects can, according to the Data Protection Authority, range across almost the entire spectrum of severity of consequences, from the less intrusive such as receiving unintended messages to more serious ones such as significant loss of reputation, to the extreme consequence where a data subject's life is endangered by the disclosure of a concealed address, to mention just a few possible consequences.

The Data Protection Authority notes that any risk that entails a high consequence for the rights and freedoms of data subjects – even with relatively low probabilities of the risk materializing – is likely to involve a high risk to the rights of the data subjects, which triggers the obligation to carry out a

consequence analysis regarding data protection, cf. Article 35, paragraph 1 of the Regulation. Furthermore, based on reports of breaches of personal data security concerning AULA, the Data Protection Authority has generally found that several of these would likely entail a high risk to the rights and freedoms of natural persons. Additionally, the Authority has in several cases found that municipalities have considered the conditions in Article 34 to be met and have notified the data subjects about breaches of personal data security in AULA. The municipalities in question have thus assessed that the breaches would likely entail a high risk to the rights and freedoms of natural persons.

Based on the above, it is the Data Protection Authority's assessment that the processing of personal data in AULA entails a high risk to the rights and freedoms of natural persons. The Data Protection Authority therefore finds that the processing activities carried out in AULA are subject to the requirement for a consequence analysis regarding data protection prior to the implementation of AULA.

#### 4.2.2. Timing of the Preparation of the Consequence Analysis

It follows from Article 35, paragraph 1 of the Data Protection Regulation that a consequence analysis regarding data protection must be carried out prior to the processing.

The Data Protection Authority assumes that Randers Municipality's consequence analysis was prepared on October 28, 2021. The Data Protection Authority has, in connection with a supervisory visit to KOMBIT in December 2019, found that there has been uncertainty regarding where the data responsibility for the processing of personal data in the solution is placed in connection with the development of AULA. Both the municipalities and KOMBIT have thus been of the opinion that the data responsibility for the processing of personal data in AULA – and thus also the responsibility for conducting risk assessments and consequence analyses – was placed with KOMBIT.

As mentioned above under point 1, the Data Protection Authority found during the relevant supervisory visit to KOMBIT that KOMBIT is not to be regarded as the data controller, and therefore the Authority informed KOMBIT that it must ensure that all municipalities are informed of their data responsibility, and that KOMBIT must transfer all necessary material and information to the municipalities in that regard.

The Data Protection Authority assumes that this uncertainty regarding data responsibility has been a reason why Randers Municipality's consequence analysis was not prepared prior to their processing of personal data in AULA. In this connection, the Data Protection Authority assumes that Randers Municipality, upon the implementation of AULA, believed that KOMBIT was the data controller for the processing of personal data in the solution.

and thus also responsible for the preparation of a risk assessment and impact analysis.

Based on the Data Protection Authority's inspection visit to KOMBIT in December 2019 and the material submitted by KOMBIT in this context, the Data Protection Authority concludes that KOMBIT, in connection with the development of AULA – and before it was established that the municipalities were data controllers – conducted assessments of the risks and consequences for the data subjects related to the processing of personal data in AULA, which show that the processing involves a high risk for the data subjects.

It is thus the Data Protection Authority's opinion that Randers Municipality – like the other municipalities – should have recognized the high risk associated with the processing of personal data in AULA when KOMBIT informed the municipalities about their data responsibility regarding the processing of personal data in AULA and transferred all necessary material in this regard.

The Data Protection Authority expects that KOMBIT informed the municipalities about this immediately after the inspection visit in December 2019. This is confirmed by the fact that it appears from Randers Municipality's impact analysis that the municipality received a template/draft for the impact analysis from KOMBIT on January 28, 2020.

However, the Data Protection Authority can ascertain that Randers Municipality is only seen to have prepared an impact analysis on October 28, 2021, which is one year and ten months after it was clarified that they were data controllers for AULA. Furthermore, the Data Protection Authority can



ascertain that the impact analysis was prepared after the inspection requested the material as part of the written supervision in the area.

It is the Data Protection Authority's opinion that Randers Municipality should have commenced the preparation of an impact analysis already upon the establishment of the municipality's data responsibility for the processing of personal data in AULA, as well as the high risk that the processing entails. The Data Protection Authority has particularly taken into account in its assessment that the purpose of an impact analysis is to identify the specific risks associated with the processing for the rights and freedoms of the data subjects and subsequently ensure that measures are established to mitigate these risks and reduce the risk to a level that is less than high before the processing begins.

On this basis, the Data Protection Authority finds that Randers Municipality, by only having prepared an impact analysis for the processing of personal data in AULA nearly two years after the municipality became aware that they were data controllers for the processing of personal data in a solution that involves a high risk for the data subjects, has acted in violation of Article 35, paragraph 1 of the General Data Protection Regulation.

#### 4.2.3. Minimum requirements for impact analyses

Article 35 of the General Data Protection Regulation contains a number of requirements that an impact analysis must meet at a minimum. These requirements follow from paragraph 7 and include the following:

- a systematic description of the planned processing activities and the purposes of the processing, including, where applicable, the legitimate interests pursued by the data controller
- an assessment of whether the processing activities are necessary and proportionate to the purposes
- an assessment of the risks to the rights and freedoms of the data subjects as referred to in paragraph 1, and
- the measures that are envisaged to address these risks, including safeguards, security measures, and mechanisms that can ensure the protection of personal data and demonstrate compliance with this regulation, taking into account the rights and legitimate interests of the data subjects and other affected persons.

The rules of the General Data Protection Regulation regarding impact analysis are intended to ensure that no processing, where there is an inherent high risk to the rights and freedoms of the data subjects, is initiated without the data controller having worked with and mitigated such risks.

An impact analysis regarding data protection is thus a tool that enables the data controller to systematically address the risks that a processing activity may entail.

The General Data Protection Regulation provides data controllers with the flexibility to determine the exact structure and form of the impact analysis regarding data protection. However, regardless of the form, an impact analysis regarding data protection must contain the above minimum requirements and thus be a proper assessment of risks that allows data controllers to take measures to mitigate them.

The Data Protection Authority has reviewed Randers Municipality's impact analysis in relation to the minimum requirements in Article 35, paragraph 7 of the General Data Protection Regulation.

It is the Authority's overall assessment that Randers Municipality has not conducted a sufficient impact analysis, pursuant to Article 35, paragraph 1 of the General Data Protection Regulation, as the submitted impact analysis does not meet the minimum requirements set out in Article 35, paragraph 7, letters a, c, and d of the Regulation.

Below follows the Data Protection Authority's assessment of the impact analysis in relation to the individual minimum requirements set out in Article 35, paragraph 7, letters a-d.

##### Ad a) Systematic description of processing activities and purposes

It is the Data Protection Authority's opinion that the requirement for a systematic description of the planned processing activities and the purposes of the processing pursuant to Article 35, paragraph 7, letter a of the General Data Protection Regulation entails that the data controllers must provide a

systematic description of the various the functionality of AULA, as certain features require personal data to operate effectively. Randers Kommune concludes that the processing of personal data is necessary to achieve the objectives of AULA, particularly in ensuring effective communication between educational institutions and parents.

#### Ad c) Assessment of risks

The Data Protection Authority notes that Randers Kommune's impact assessment includes an evaluation of the risks associated with the processing activities. The assessment identifies potential risks to the rights and freedoms of data subjects, particularly concerning the processing of sensitive personal data. It emphasizes the importance of implementing appropriate technical and organizational measures to mitigate these risks.

The assessment further outlines the measures that have been put in place to protect personal data, including access controls, data encryption, and regular audits. However, the Data Protection Authority finds that the assessment does not sufficiently address all potential risks, particularly those related to unauthorized access and data breaches.

In conclusion, while Randers Kommune has made efforts to comply with the requirements of the General Data Protection Regulation (GDPR), the Data Protection Authority believes that the impact assessment lacks the necessary detail and comprehensiveness. The Authority recommends that Randers Kommune enhance their assessment by providing a more thorough description of the processing activities, including all forms of processing and the types of sensitive personal data involved, as well as a more detailed risk analysis.

userSure, here is the translation of the provided legal document text into English:

---

the user-friendliness in a negative direction. Likewise, it appears that the purpose of processing personal data in AULA can to some extent be achieved by using anonymized, aggregated, or pseudonymized data, but not without affecting user-friendliness. Furthermore, Randers Municipality in the impact assessment has, among other things, considered how to ensure that correct information is processed, when personal data is deleted, and how the rights of the data subjects are handled. However, the Data Protection Agency recommends that Randers Municipality, in a later update of the impact assessment, expands the evaluation to also include how the relationship between the data subjects and Randers Municipality as the data controller is, and in this context whether the processing of personal data is voluntary, as well as whether the data subjects can expect such processing of their personal data.

#### Ad c) and d) Assessment of risks and measures

Randers Municipality's impact assessment refers to the municipality's risk assessment in an Excel sheet, which has also been submitted to the Data Protection Agency. The risk assessment contains an evaluation of the risks to the rights and freedoms of the data subjects, as well as a description of the measures that are intended to address these risks. The impact assessment includes a listing of three of the six measures that are included in the municipality's risk assessment. In addition, Randers Municipality has in a separate annex explained how the municipality has worked with the risks that were identified as high (red) in the material submitted by KOMBIT. Randers Municipality thus appears to have worked with the risks that the processing of personal data in AULA entails.

As stated above under section 4.1.3, it is, however, the Data Protection Agency's assessment that Randers Municipality has not demonstrated, in identifying the risks that the processing of personal data in AULA poses for the data subjects, whether and to what extent there are high risks associated with the processing of personal data in AULA. Furthermore, it is the Data Protection Agency's assessment that Randers Municipality has not demonstrated that the measures implemented to reduce the identified risks associated with the processing of personal data in AULA are sufficient to reduce the risk to a low level. In this regard, reference is made to section 4.1.4 above. Thus, it is the Data Protection Agency's assessment that Randers Municipality has not shown that they have ensured a level of security that is appropriate to the risks that the processing of personal data in AULA

entails. It is against this background that the Data Protection Agency assesses that the content of the impact assessment regarding the municipality's evaluation of the risks and the listed measures is not sufficient to meet the minimum requirements in Article 35, paragraph 7, letters c and d.

#### 4.2.4. Requirement to consult the data protection officer

It follows from Article 35, paragraph 2 of the Data Protection Regulation that the data controller must consult the data protection officer, if one has been appointed, when conducting an impact assessment regarding data protection. Furthermore, it follows from Article 39, paragraph 1, letter c of the Regulation that the data protection officer must, at a minimum, provide advice when requested regarding the impact assessment concerning data protection and monitor its compliance according to Article 35. The Data Protection Agency assumes that Randers Municipality has consulted the municipality's data protection officer, as it appears from section 8 of the impact assessment that the data protection officer has been involved from the beginning and continuously in the process of preparing the impact assessment. Additionally, it is stated in the first section of the impact assessment that Randers Municipality's data protection officer points out that the impact assessment should have been conducted before the implementation and commissioning of the system, and that Randers Municipality must ensure that the appropriate security measures are in place before the system is put into use.

#### 4.2.5. Overall assessment regarding the impact assessment

After reviewing Randers Municipality's impact assessment, the Data Protection Agency finds that Randers Municipality has not conducted a satisfactory impact assessment, cf. Article 35, paragraph 1 of the Data Protection Regulation, as the submitted impact assessment does not meet the minimum requirements set out in Article 35, paragraph 7, letters a, c, and d of the Regulation. The Data Protection Agency further finds that Randers Municipality, by only having prepared an impact assessment for the processing of personal data in AULA nearly two years after it became clear that the municipality is the data controller for the processing of personal data in a solution that entails a high risk for the data subjects, has acted in violation of Article 35, paragraph 1 of the Data Protection Regulation. The Data Protection Agency finds it serious that the impact assessment appears to have been prepared only after the Data Protection Agency requested the material as part of the written supervision in the area.

Against this background, the Data Protection Agency finds grounds to express serious criticism that Randers Municipality's processing of personal data has not been carried out in accordance with Article 35, paragraph 1 of the Regulation. In choosing a reaction, the Data Protection Agency has emphasized that Randers Municipality has prepared an impact assessment for the processing of personal data in AULA that contains the elements outlined in Article 35, paragraph 7, letters a-d. However, in the Data Protection Agency's opinion, Randers Municipality's impact assessment is not sufficiently detailed. In this regard, the Data Protection Agency notes that a systematic description of the processing activities must contribute to the...

---

Please let me know if you need any further assistance!

#### **\*\*Data Controllers' Assessment of High Risks\*\***

Specific likelihood and severity taking into account the nature, scope, context, and purpose of the processing as well as the sources of risk. Furthermore, the content of the impact assessment regarding the municipality's evaluation of the risks and the listed measures is not sufficient to meet the minimum requirements of Article 35, paragraph 7, letters c and d.

The Data Protection Authority has also emphasized the timing of Randers Municipality's preparation of the impact assessment.

In this context, the Data Protection Authority notes that the purpose of an impact assessment is to identify the specific risks associated with the processing for the rights and freedoms of the data subjects and subsequently ensure that measures are established to mitigate these risks and reduce the risk to a level that is less than high before the processing begins. It is the opinion of the Data Protection Authority that Randers Municipality should have commenced the preparation of an impact

assessment upon recognizing the municipality's data responsibility for the processing of personal data in AULA and the high risk that the processing entails.

#### **\*\*4.3. Summary\*\***

On the above basis, the Data Protection Authority finds grounds to express criticism that Randers Municipality's processing of personal data has not occurred in accordance with the Data Protection Regulation's Article 5, paragraph 2, in conjunction with paragraph 1, letter f, and Article 24, paragraph 1, in conjunction with Article 32, paragraph 1.

The Data Protection Authority further finds grounds to express serious criticism that Randers Municipality's processing of personal data has not occurred in accordance with the Regulation's Article 35, paragraph 1.

#### **\*\*4.4. General Remarks from the Data Protection Authority\*\***

In system landscapes where multiple data controllers use the same systems and perform approximately the same processing of personal data, there can be significant synergy in conducting joint assessments regarding risk factors, potential impact assessments, and mitigating measures. The Data Protection Authority notes that it may be relevant to conduct a joint impact assessment if several data controllers are planning to implement a shared IT system or processing platform, for example, within the municipal sector. For multiple data controllers to collaborate on preparing a joint impact assessment, it is a prerequisite that the same type of system is involved, the same processing activity of the same personal data, and that the processing activities entail similar high risks.

It is not crucial that there is full identity between the systems and processing activities, but that the system, data, and particularly the processing activities do not deviate significantly from each other. Otherwise, a supplement to the joint impact assessment must necessarily be prepared.

Thus, it is the opinion of the Data Protection Authority that it would be sufficient for several municipalities to prepare one impact assessment regarding data protection for the processing of personal data in the same system, provided by the same supplier, if the same processing activities are performed in the system, the same types of personal data are processed, and the processing activities involve the same high risks.

It is the data controllers who specifically assess whether a joint impact assessment can be conducted for the processing activities in the systems. The data controllers in a joint impact assessment are each responsible for conducting the impact assessment.

It is the opinion of the Data Protection Authority that, in relation to the municipalities' processing of personal data in AULA, the municipalities are using the same type of system for the same processing activities of the same types of personal data, and that the municipalities' processing activities entail similar high risks. Furthermore, the system is provided by the same supplier. Thus, the municipalities have the opportunity to prepare a joint impact assessment regarding data protection for their processing of personal data in AULA.

In associations and bodies that represent categories of data controllers, it can also be beneficial to develop codes of conduct in accordance with Article 40 of the Data Protection Regulation with the aim of specifying the application of the Data Protection Regulation.

A code of conduct can provide correct and practical guidance on how to organize oneself in connection with one or more processing activities to comply with data protection rules. This may, for example, involve establishing procedures to be followed for a specific processing activity. A code of conduct will therefore be a useful tool to assist in complying with data protection rules for the authorities that have adhered to the code. This facilitates compliance with the rules but does not relieve the individual data controller of the obligations and tasks that fall upon them as data controllers. This is particularly significant in situations where the data controller chooses to deviate from the assumptions in the common concepts and processing, for example, by using a system for other purposes.

On this basis, the Data Protection Authority encourages consideration across municipalities and possibly in collaboration with KL and KOMBIT to develop a code of conduct in accordance with Article 40 of the Data Protection Regulation regarding the municipalities' processing of personal data in AULA. This may also be relevant to consider in relation to other processing activities in the municipalities, where the municipalities use the same system for processing the same types of

personal data for the same purposes.

[1] Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data and repealing Directive 95/46/EC (General Data Protection Regulation).

[2] Act No. 502 of 23 May 2018 on supplementary provisions to the regulation on the protection of natural persons with regard to the processing of personal data and on the free movement of such data (Data Protection Act).

[3] KL has described the User Portal Initiative on their website: <https://www.kl.dk/kommunale-opgaver/boern-og-unge/digitalisering-paa-boerne-og-ungeomraadet/brugerportalsinitiativet/>

[4] KOMBIT provides information about AULA on the website <https://aulainfo.dk/om-aula/>

[5] It appears from the material on the User Portal Initiative, which is available on KL's website: <https://www.kl.dk/media/11560/illustration-af-aftaler-om-databehandling-i-og-omkring-bpi.pdf>

[6] <https://aulainfo.dk/wp-content/uploads/Sletteprocedurer-og-sletteregler-i-Aula-v1.0.pdf>

[7] Guidelines for Data Protection Impact Assessment (DPIA) and determining whether the processing "likely results in a high risk" under Regulation (EU) 2016/679, WP248 rev. 01, adopted on 4 April 2017, as last revised and adopted on 4 October 2017.

[8] From recital 90, it is stated: "In such cases, the data controller should, prior to processing, carry out a data protection impact assessment to assess the specific likelihood and severity of the high risk, taking into account the nature, scope, context, and purposes of the processing as well as the sources of risk. The impact assessment should particularly include the measures, safeguards, and mechanisms that are planned to mitigate this risk, to ensure the protection of personal data and to demonstrate compliance with this regulation."

[9] Reference is made to the Danish Data Protection Authority's guidance on impact assessment from March 2018.